

Gerência de Projetos

Aula 17

Evandro J.R. Silva

Sumário

- 1 Engenharia de segurança de software
- 2 *Security Development Lifecycle - SDL*
- 3 Pontos de contato
- 4 OWASP
- 5 Atividade

Engenharia de segurança de software

1 Engenharia de segurança de software

2 *Security Development Lifecycle - SDL*

3 Pontos de contato

4 OWASP

5 Atividade

Engenharia de segurança de software

- Temos software em todo lugar: celular, tablet, notebook, geladeira, microondas, máquina de lavar, carro, caixa eletrônico, sistema financeiro, [rede elétrica](#), etc.
- Todo produto de software tem o potencial de ser hackeado.

Engenharia de segurança de software

- Temos software em todo lugar: celular, tablet, notebook, geladeira, microondas, máquina de lavar, carro, caixa eletrônico, sistema financeiro, *rede elétrica*, etc.
- Todo produto de software tem o potencial de ser hackeado.
 - *Malwares* podem interceptar comandos legítimos enviados por operadores do sistema e trocá-los por instruções maliciosas.
 - Ao mesmo tempo, o *malware* calcula quais deveriam ser as leituras dos sensores da rede se estivessem operando normalmente, e envia esses valores fictícios para a sala de controle.

Engenharia de segurança de software

- Temos software em todo lugar: celular, tablet, notebook, geladeira, microondas, máquina de lavar, carro, caixa eletrônico, sistema financeiro, [rede elétrica](#), etc.
 - Todo produto de software tem o potencial de ser hackeado.
-
- Por exemplo, o *malware* pode ficar enviando comandos para os disjuntores fiquem abrindo e fechando rapidamente. Isso pode causar incêndios e explosões.

Engenharia de segurança de software

- Exemplos reais
 - **Stuxnet**: destruiu centrífugas enriquecedoras de urânio do Irã, em 2009.

Engenharia de segurança de software

■ Exemplos reais

- **Stuxnet**: destruiu centrífugas enriquecedoras de urânio do Irã, em 2009.
- **Industroyer**: ataque de malware Russo contra a Ucrânia em 2016, utilizou os próprios protocolos de comunicação da rede elétrica da Ucrânia para abrirem disjuntores e cortassem o fornecimento de eletricidade para Kyiv.

Engenharia de segurança de software

■ Exemplos reais

- **Stuxnet**: destruiu centrífugas enriquecedoras de urânio do Irã, em 2009.
- **Industroyer**: ataque de malware Russo contra a Ucrânia em 2016, utilizou os próprios protocolos de comunicação da rede elétrica da Ucrânia para abrirem disjuntores e cortassem o fornecimento de eletricidade para Kyiv.
- **Volt Typhoon**: ataque da China contra a infraestrutura crítica dos EUA, exposta em 2023, em resposta ao suporte dos EUA a Taiwan. Nesse ataque os hackers conseguiram acesso a redes de comunicação, construção, governo, transporte, energia, dentre outros.

Engenharia de segurança de software

- Vulnerabilidade de cadeia de suprimentos
 - A vulnerabilidade reside sobre a cadeia de suprimentos de **controladores**. Alguns usam códigos de bibliotecas datadas, ou sem suporte, e também existem os controladores que possuem seus sites administrativos, os quais podem ser pontos de vulnerabilidade.
 - Quando algum operador de uma fábrica fizer o login, um código malicioso pode ser ativado para se aproveitar de uma sessão legítima, contornando *firewalls* e enviando comandos para o equipamento físico, sem a necessidade de quebra de senha do dispositivo.
 - Esses controladores estão em diversos equipamentos, inclusive equipamentos médicos.

Engenharia de segurança de software

- [Lista](#) de cyber incidentes significativos, desde 2006.

Security Development Lifecycle - SDL

- 1 Engenharia de segurança de software
- 2 *Security Development Lifecycle - SDL*
- 3 Pontos de contato
- 4 OWASP
- 5 Atividade

Security Development Lifecycle - SDL

- É um processo de segurança de software de iniciativa da Microsoft.
- O SDL introduz a segurança e a privacidade no início do trabalho e em todas as fases do processo de desenvolvimento. É o modelo do ciclo de vida do desenvolvimento da segurança mais conhecido e mais utilizado.

Security Development Lifecycle - SDL

- A Microsoft definiu um conjunto de princípios chamados de *Seguro por Design*, *Seguro por Padrão (Default)*, *Seguro na Implantação (Deployment)* e *Comunicações (SD3+C)* para ajudar a determinar onde os esforços de segurança são necessários.

Security Development Lifecycle - SDL

■ Seguro por Design

- Arquitetura, projeto e estrutura seguros.
- Modelagem de ameaças e mitigação.
- Eliminação de vulnerabilidades.
- Melhorias na segurança.

■ Seguro por Padrão (Default)

Security Development Lifecycle - SDL

■ Seguro por Design

■ Seguro por Padrão (Default)

- Privilégios mínimos.
- Defesa em profundidade.
- Configurações de padrões conservadoras.
- Evitar alterações arriscadas de padrões.
- Serviços menos usados desabilitados por padrão.

Security Development Lifecycle - SDL

- **Seguro na Implantação (Deployement)**
 - Guias de implantação.
 - Ferramentas de análise e gestão.
 - Ferramentas de implantação de *patches*.
- **Comunicações**
 - Resposta de segurança.
 - Envolvimento da comunidade.

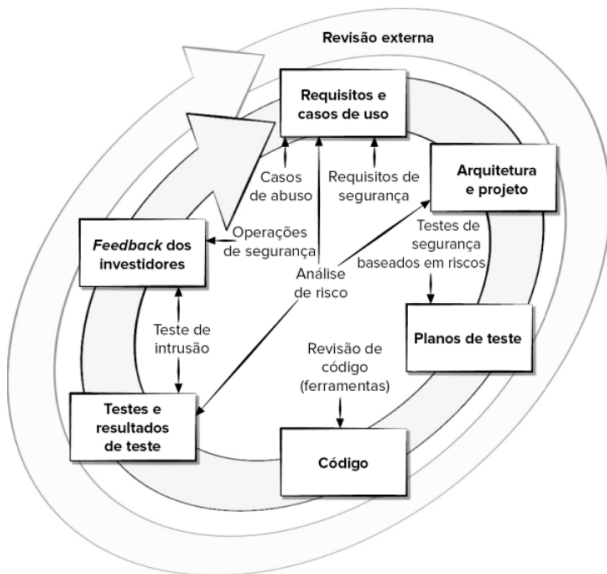
Pontos de contato

- 1 Engenharia de segurança de software
- 2 *Security Development Lifecycle - SDL*
- 3 **Pontos de contato**
- 4 OWASP
- 5 Atividade

Pontos de contato

- É independente do modelo de ciclo de vida.
- Algumas organizações consideram os pontos de contato como o conjunto mínimo de atividades que devem ser realizadas no desenvolvimento seguro de software.

Pontos de contato



Pontos de contato

- A partir do SDL e dos pontos de contato é possível definir e implementar políticas e atividades de segurança ao longo do desenvolvimento, como por exemplo:
 - **Engenharia de requisitos de segurança.**

Pontos de contato

- A partir do SDL e dos pontos de contato é possível definir e implementar políticas e atividades de segurança ao longo do desenvolvimento, como por exemplo:
 - **Engenharia de requisitos de segurança.**
 - **Levantamento de casos de mau uso, abuso e padrões de ataque.**

Pontos de contato

- A partir do SDL e dos pontos de contato é possível definir e implementar políticas e atividades de segurança ao longo do desenvolvimento, como por exemplo:
 - **Engenharia de requisitos de segurança.**
 - **Levantamento de casos de mau uso, abuso e padrões de ataque.**
 - **Análise de risco de segurança.**

Pontos de contato

- A partir do SDL e dos pontos de contato é possível definir e implementar políticas e atividades de segurança ao longo do desenvolvimento, como por exemplo:
 - **Engenharia de requisitos de segurança.**
 - **Levantamento de casos de mau uso, abuso e padrões de ataque.**
 - **Análise de risco de segurança.**
 - **Modelagem de ameaças, priorização e mitigação:** uma abordagem para criar uma abstração de um sistema de software com o objetivo de identificar as habilidades e os objetivos dos invasores e utilizar essa abstração para gerar e catalogar possíveis ameaças que o sistema deve mitigar.

Pontos de contato

- A partir do SDL e dos pontos de contato é possível definir e implementar políticas e atividades de segurança ao longo do desenvolvimento, como por exemplo:
 - **Engenharia de requisitos de segurança.**
 - **Levantamento de casos de mau uso, abuso e padrões de ataque.**
 - **Análise de risco de segurança.**
 - **Modelagem de ameaças, priorização e mitigação**

- **Superfície de ataque:** descreve todos os diferentes pontos nos quais um invasor pode entrar em um sistema e dos quais ele poderia extrair dados.

Pontos de contato

- A partir do SDL e dos pontos de contato é possível definir e implementar políticas e atividades de segurança ao longo do desenvolvimento, como por exemplo:
 - Engenharia de requisitos de segurança.
 - Levantamento de casos de mau uso, abuso e padrões de ataque.
 - Análise de risco de segurança.
 - Modelagem de ameaças, priorização e mitigação

- Superfície de ataque

- Codificação segura.

OWASP

- 1 Engenharia de segurança de software
- 2 *Security Development Lifecycle - SDL*
- 3 Pontos de contato
- 4 **OWASP**
- 5 Atividade

OWASP

- O OWASP (*Open Worldwide Application Security Project*) é uma fundação sem fins lucrativos que trabalha para melhorar a segurança de software.
- Consiste em uma comunidade aberta dedicada a capacitar organizações a conceber, desenvolver, adquirir, operar e manter aplicações confiáveis.

OWASP

- Alguns de seus principais projetos são:
 - **OWASP Top Ten Web Application Security Risks**: é um documento padrão de conscientização para desenvolvedores e segurança de aplicações web. Ele representa um amplo consenso sobre os riscos de segurança mais críticos para aplicações web.

OWASP

- Alguns de seus principais projetos são:
 - **OWASP Application Security Verification Standard (ASVS)**: fornece uma base para testar os controles técnicos de segurança de aplicações web e também oferece aos desenvolvedores uma lista de requisitos para o desenvolvimento seguro.

OWASP

- Alguns de seus principais projetos são:
 - **OWASP Mobile Application Security**: fornece um padrão de segurança e privacidade para aplicativos mobile (OWASP MASVS), uma coleção de pontos fracos específicos de aplicativos mobile (OWASP MASWE) e um guia de teste completo (OWASP MASTG) que cobre os processos, técnicas e ferramentas usados durante o teste de segurança, como também um conjunto exaustivo de casos de teste que permite aos testadores fornecerem resultados consistentes e completos.

OWASP

- Alguns de seus principais projetos são:
 - [OWASP Web Security Testing Guide](#) (WSTG): é um guia completo para o teste de segurança de aplicações web e *web services*, e fornece um *framework* das melhores práticas usadas por *pen testers* e organizações ao redor do mundo.

Atividade

- 1 Engenharia de segurança de software
- 2 *Security Development Lifecycle - SDL*
- 3 Pontos de contato
- 4 OWASP
- 5 **Atividade**

Atividade

- Para sala de aula
 - Pesquisar e apresentar o [Top 10 2025 do OWASP](#).
 - A turma será dividida em dois grupos, e cada grupo ficará responsável por cinco riscos.
- Para o trabalho (AV3)
 - Implementar pelo menos cinco requisitos (*requirements*) de nível 1 do [ASVS](#).
 - Conduzir pelo menos três testes do [WSTG](#).

FIM